



AWS CloudTrail

© 2020, Amazon Web Services, Inc. ou uma afilada. Todos os direitos reservados.

A lição agora explorará o AWS CloudTrail.

O que você aprenderá

Principais pontos da lição

Você aprenderá a:

- Explicar a finalidade e a função do AWS CloudTrail.

Tópicos:

- AWS CloudTrail

Principais termos:

- Entrada de registro de log
- requestParameters
- responseElements



Ao final do módulo, você será capaz de:

- Explicar a finalidade e a função do AWS CloudTrail.

AWS CloudTrail

O AWS CloudTrail é um serviço que:

- Registra em log, monitora continuamente e retém a atividade da conta relacionada a ações na sua infraestrutura da AWS.
- Registra chamadas de interface de programação de aplicativos (API) para a maioria dos serviços da AWS.
 - As atividades do Console de gerenciamento da AWS e da AWS Command Line Interface (AWS CLI) também são registradas.
- É compatível com um número crescente de serviços da AWS.
- Envia logs automaticamente para o Amazon Simple Storage Service (Amazon S3) depois que ele é configurado.
- Não rastreia eventos em uma instância do Amazon Elastic Compute Cloud (Amazon EC2).
 - Exemplo: desligamento manual de uma instância.



AWS CloudTrail



3

O AWS CloudTrail é um serviço da AWS que gera logs de chamadas para a interface de programação de aplicativos (API) da AWS. A API da AWS está subjacente à AWS Command Line Interface (AWS CLI) e ao Console de gerenciamento da AWS. Assim, o CloudTrail pode registrar todas as atividades em relação aos serviços que ele monitora. Ele permite a governança, a conformidade, a auditoria operacional e a auditoria de riscos de contas da AWS.

Um grande (e crescente) número de serviços da AWS é compatível. Para obter detalhes, consulte [Serviços e integrações compatíveis com o CloudTrail](#).

Depois que o CloudTrail é configurado, ele envia os logs de auditoria para o Amazon Simple Storage Service (Amazon S3). Embora o AWS CloudTrail seja completo, ele não rastreia eventos que *ocorrem em* uma instância do Amazon Elastic Compute Cloud (Amazon EC2). Por exemplo, o CloudTrail não rastreia quando alguém desliga manualmente uma instância usando uma conexão de

O AWS CloudTrail é um serviço da AWS que gera logs de chamadas para a interface de programação de aplicativos (API) da AWS. A API da AWS está subjacente à AWS Command Line Interface (AWS CLI) e ao Console de gerenciamento da AWS. Assim, o CloudTrail pode registrar todas as atividades em relação aos serviços que ele monitora. Ele permite a governança, a conformidade, a auditoria operacional e a auditoria de riscos de contas da AWS.

Um grande (e crescente) número de serviços da AWS é compatível. Para obter detalhes, consulte [Serviços e integrações compatíveis com o CloudTrail](#).

Depois que o CloudTrail é configurado, ele envia os logs de auditoria para o Amazon Simple Storage Service (Amazon S3). Embora o AWS CloudTrail seja completo, ele não rastreia eventos que *ocorrem em* uma instância do Amazon Elastic Compute Cloud (Amazon EC2). Por exemplo, o CloudTrail não rastreia quando alguém desliga manualmente uma instância usando uma conexão de sessão do Secure Shell (SSH) com a instância. Ele poderia emitir um comando como **sudo shutdown -h now**.

Exemplo do CloudTrail

O CloudTrail pode ajudá-lo a responder a perguntas que exigem análise detalhada.

Quem encerrou uma instância específica?

Quem alterou a configuração de um grupo de segurança?

Há alguma atividade proveniente de um intervalo de endereços IP desconhecido?

Quais atividades foram negadas devido à falta de permissões?

4

aws re/start

Usando o CloudTrail, você pode armazenar logs sobre o uso da API em um bucket do S3. Posteriormente, você pode analisar esses logs para responder a várias perguntas, como:

- Por que uma instância de longa execução foi encerrada e quem a encerrou? As respostas podem ser úteis para a rastreabilidade e prestação de contas organizacionais.
- Quem alterou a configuração de um grupo de segurança? As equipes de auditoria de prestação de contas e segurança podem querer saber essas informações.
- Há alguma atividade proveniente de um intervalo de endereços IP desconhecido? Essa atividade pode indicar um possível ataque externo, o que é uma preocupação de segurança.

Há alguma atividade proveniente de um intervalo de endereços IP desconhecido?

Quais atividades foram negadas devido à falta de permissões?

4

aws re/start

Usando o CloudTrail, você pode armazenar logs sobre o uso da API em um bucket do S3. Posteriormente, você pode analisar esses logs para responder a várias perguntas, como:

- Por que uma instância de longa execução foi encerrada e quem a encerrou? As respostas podem ser úteis para a rastreabilidade e prestação de contas organizacionais.
- Quem alterou a configuração de um grupo de segurança? As equipes de auditoria de prestação de contas e segurança podem querer saber essas informações.
- Há alguma atividade proveniente de um intervalo de endereços IP desconhecido? Essa atividade pode indicar um possível ataque externo, o que é uma preocupação de segurança.
- Quais atividades foram negadas devido à falta de permissões? Uma atividade como essa pode indicar tentativas de ataque internas ou externas.

Configure uma trilha

As etapas para configurar uma trilha são:

1. Configurar um bucket novo ou existente do Amazon Simple Storage Service (Amazon S3) para fazer upload de arquivos de log.
2. Definir uma trilha para registrar os eventos desejados (todos os eventos de gerenciamento são registrados por padrão).
3. Criar um tópico do Amazon Simple Notification Service (Amazon SNS) para receber notificações.
4. Configurar o Amazon CloudWatch Logs para receber logs do CloudTrail (opcional).
5. Ativar a criptografia de arquivos de log e a validação de integridade para arquivos de log (opcional).
6. Adicionar tags à sua trilha (opcional).



5

aws re/start

Por padrão, quando você acessa o histórico de eventos do CloudTrail para a região que está visualizando, o CloudTrail só mostrará os resultados dos últimos 90 dias. Esses eventos são limitados aos eventos de gerenciamento com chamadas de APIs para criar, modificar e excluir, além da atividade da conta. Para obter um *registro completo* da atividade da conta, incluindo todos os eventos de gerenciamento, eventos de dados, bem como todas as atividades somente leitura, será necessário configurar uma *trilha* do CloudTrail.

Você pode criar uma trilha usando o console do CloudTrail ou a AWS CLI.

As seguintes opções podem ser configuradas:

1. Crie um bucket do S3 ou especifique um bucket existente no qual você deseja que os arquivos de log sejam armazenados.
2. Configure a sua trilha para registrar eventos *somente leitura, somente*

Por padrão, quando você acessa o histórico de eventos do CloudTrail para a região que está visualizando, o CloudTrail só mostrará os resultados dos últimos 90 dias. Esses eventos são limitados aos eventos de gerenciamento com chamadas de APIs para criar, modificar e excluir, além da atividade da conta. Para obter um *registro completo* da atividade da conta, incluindo todos os eventos de gerenciamento, eventos de dados, bem como todas as atividades somente leitura, será necessário configurar uma *trilha* do CloudTrail.

Você pode criar uma trilha usando o console do CloudTrail ou a AWS CLI.

As seguintes opções podem ser configuradas:

1. Crie um bucket do S3 ou especifique um bucket existente no qual você deseja que os arquivos de log sejam armazenados.
2. Configure a sua trilha para registrar eventos *somente leitura*, *somente gravação* ou *todos* os eventos de gerenciamento e dados. Por padrão, as trilhas registram todos os eventos de gerenciamento.
3. Crie um tópico do Amazon Simple Notification Service (Amazon SNS) para receber notificações quando os arquivos de log forem entregues.
4. Opcionalmente, configure o Amazon CloudWatch Logs para receber logs do CloudTrail para que você possa monitorar eventos de log específicos.
5. Opcionalmente, ative a *criptografia de arquivos de log* para maior segurança.
6. Como opção, adicione tags (pares de chave-valor personalizados) à sua

Exemplo de entrada de log do AWS CloudTrail: requestParameters

Este exemplo mostra uma seção `requestParameters` de uma entrada de log. Ela inclui parâmetros como:

- **userIdentity** — Quem (ou qual aplicativo) realizou uma ação.
- **eventTime** — A data e a hora em que a ação ocorreu.
- **eventSource** — Uma indicação de se a ação foi feita por meio do console, da AWS CLI ou da chamada da API.

```
{  "eventVersion" : "1.01",
    "userIdentity" : {
      "type" : "IAMUser",
      "principalId" : "AIDAAAAAAAAAAAAAAAA",
      "arn" : "arn:aws:iam:xxxxxxxxxxxx:user/tests3user",
      "accountId" : "xxxxxxxxxxxx",
      "userName" : "tests3user"
    },
    "eventTime" : "2018-09-23T22:41:38Z",
    "eventSource" : "signin.amazonaws.com",
    "eventName" : "ConsoleLogin",
    "awsRegion" : "us-east-1",
    "sourceIPAddress" : "54.240.217.10",
    "userAgent" : "Mozilla/5.0 (Windows NT 6.1; WOW64; rv:31.0) Gecko/20100101 Firefox/31.0",
  }
```

6



Cada arquivo de log do CloudTrail formatado pelo JavaScript Object Notation (JSON) pode conter uma ou mais registros de log.

Uma *entrada de log* representa uma única solicitação de qualquer fonte. Ela inclui informações sobre a ação de solicitação e a resposta.

O exemplo mostra a seção `requestParameters` de uma entrada de log. Ela inclui parâmetros como:

- **userIdentity** — Quem (ou qual aplicativo) realizou uma ação.
- **eventTime** — A data e a hora em que a ação ocorreu.
- **eventSource** — Uma indicação de se a ação foi feita por meio do console

Cada arquivo de log do CloudTrail formatado pelo JavaScript Object Notation (JSON) pode conter uma ou mais registros de log.

Uma *entrada de log* representa uma única solicitação de qualquer fonte. Ela inclui informações sobre a ação de solicitação e a resposta.

O exemplo mostra a seção **requestParameters** de uma entrada de log. Ela inclui parâmetros como:

- **userIdentity** — Quem (ou qual aplicativo) realizou uma ação.
- **eventTime** — A data e a hora em que a ação ocorreu.
- **eventSource** — Uma indicação de se a ação foi feita por meio do console, da AWS CLI ou da chamada da API.

Parâmetros adicionais também podem ser incluídos. A lista real de parâmetros depende do tipo de ação que foi registrada.

Não é garantido que as entradas de log estejam em uma ordem específica. Elas não são um rastreamento de pilha de ordem de chamadas de API.

Registro de log do CloudTrail: responseElements (exemplo de sucesso)

Este exemplo mostra a seção responseElements da mesma entrada de log de amostra.

```
"responseElements" : {  
  "ConsoleLogin" : "Success"  
},  
  "additionalEventData" : {  
    "MobileVersion" : "No",  
    "LoginTo" :  
    "https://console.aws.amazon.com/console/home?state\u003dhas  
hArgs%23\u0026isauthcode\u003dtrue",  
    "MFAUsed" : "No"  
  },  
  "eventID" : "b31716e9-13e5-4fb5-9c60-  
1c723c59f5a6"  
}
```

7

aws re/start

Este exemplo mostra a seção **responseElements** da mesma entrada de log de exemplo.

Nesse caso, a tentativa de fazer login no console foi bem-sucedida. O usuário não usou a versão móvel do console, além de não ter usado a autenticação multifator (MFA) para fazer login.

Registro de log do AWS CloudTrail: responseElements (exemplo de falha)

Este exemplo é a seção responseElements de uma tentativa de login para um registro de log de amostra diferente.

```
"errorMessage" : "Failed authentication",
"requestParameters" : null,
"responseElements" : {
  "ConsoleLogin" : "Failure"
},
"additionalEventData" : {
  "MobileVersion" : "No",
  "LoginTo" :
    "https://console.aws.amazon.com/console/home?state
    \u003dhashArgs%23\u0026isauthcode\u003dtrue",
  "MFAUsed" : "No"
},
"eventID" : "99dc0ee0-ec1d-4a14-bb74-
10407b3b8ab1"
},
```

8

aws re/start

Este exemplo é a seção **responseElements** de uma tentativa de login para uma entrada de log de exemplo diferente.

Neste exemplo, a tentativa de login não foi bem-sucedida.

Monitoramento e segurança

Examine o CloudWatch Logs e o CloudTrail para detectar possíveis usos não autorizados.

Exemplos:

- Tentativas fracassadas de login no Console de gerenciamento da AWS ou de login de endereços IP suspeitos
- Acesso não autorizado aos serviços que usam a API
- Execuções suspeitas de recursos

Quando você monitora a atividade na sua conta e protege seus recursos e dados, os recursos do CloudWatch e do CloudTrail são complementares. Recomenda-se o uso de ambos os serviços. Por exemplo, você pode examinar os logs das entradas do CloudWatch Logs e do CloudTrail para detectar potenciais usos não autorizados.

Outros exemplos de usos desses serviços incluem:

- Monitorar as tentativas de login com falha no Console de gerenciamento da AWS, especialmente tentativas de login de endereços IP suspeitos
- Detectar acesso não autorizado a serviços por meio de chamadas de API
- Identificar um lançamento suspeito de recursos da AWS

Principais conclusões



© 2020, Amazon Web Services, Inc. ou suas afiliadas. Todos os direitos reservados.

10

- O AWS CloudTrail permite a auditoria de contas da AWS registrando continuamente a atividade da conta.
- As informações que o CloudTrail captura podem ser enviadas para serviços de armazenamento, como o Amazon S3, ou para ferramentas de relatórios de negócios.
- O monitoramento de registros é parte integrante de uma postura de segurança profissional.

aws re/start

A principal conclusão desta seção é:

- O AWS CloudTrail permite a auditoria de contas da AWS registrando a atividade da conta de forma contínua.
- As informações que o CloudTrail captura podem ser enviadas para serviços de armazenamento, como o Amazon S3, ou para ferramentas de relatórios de negócios.
- O monitoramento de registros é parte integrante de uma postura de segurança profissional.